

Exploiting an API Endpoint Using Documentation

Author: Moe Htet Ar Kar (Phoe Cho)

1. Vulnerability Concept & Mechanics

Modern applications frequently publish API documentation, such as Swagger UI, OpenAPI specifications, Postman collections, or Redoc, to facilitate developer integration and client-side consumption.

However, publicly exposed documentation may reveal sensitive endpoints, administrative functionality, or test routes. When documented endpoints lack appropriate authentication or authorization controls, attackers can use the documentation as an attack-surface map to identify high-privilege operations.

2. Attack Vector & Exploitation Methodology

Documentation Discovery

Perform reconnaissance for common API documentation paths, such as `/api/`, `/swagger-ui.html`, `/openapi.json`, and `/api-docs/`.

Endpoint Analysis

Analyze the retrieved API specification to identify available HTTP methods, parameters, data types, authentication requirements, and endpoint paths.

Authorization Testing

Identify sensitive endpoints and verify whether appropriate authentication and authorization controls are enforced before privileged operations are executed.

API Attribute	Description	Red Team Assessment Objective
Endpoint Schema	Maps paths and parameters	Identify management and administrative routes.
HTTP Methods	GET, POST, PUT, DELETE, etc.	Identify potentially high-impact operations.
Parameter Constraints	Expected types and structures	Assess input validation and authorization boundaries.

3. Validation & Impact

- **Impact:** Potential horizontal or vertical privilege escalation, unauthorized account modification, data exposure, or unauthorized administrative actions.
- **Validation:** Verify whether a privileged API operation can be performed without the required authentication or authorization privileges.

4. Remediation & Hardening

- Restrict API documentation portals to authorized users or trusted networks where appropriate.

- Enforce centralized authentication and authorization middleware on every backend route.
- Apply the Principle of Least Privilege to API permissions.
- Ensure that documentation exposure does not imply authorization to execute the documented operations.